Threat Model & Quantitative Risk Assessment Report

Course: CYC386 Secure Software Design and Development | **Sprint:** Midterm Lab Exam (Fall 2026)
Instructor: Engr. Muhammad Ahmad Nawaz | **Team:** Muhammad Tallat (FA23-BCT-029), Sadat Ali (FA23-BCT-034), Hassaan Shakoor (FA23-BCT-054)
Live Jira Board: https://securebank-test123.atlassian.net/jira/software/projects/CV/boards/2

1. System Architecture & DFD Overview

CloudVault is partitioned into three trust boundaries: Untrusted Client Zone, Application DMZ, and Host OS & Persistence Layer. Data flows between these boundaries were analyzed using STRIDE.

2. STRIDE Threat Analysis & CVSS v3.1 Quantitative Risk Scores

Threat ID	Element	STRIDE Category	CVSS v3.1 Vector	Score / Severity	Jira
T-01	Process 4.0 Native Parser	Tampering / Elevation of Privilege	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	**8.8 (High)**	CV-14
T-02	Process 3.0 Diagnostics	Elevation of Privilege (CWE-78)	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H	**9.9 (Critical)**	CV-12
T-03	Process 2.0 Document Vault	Information Disclosure (CWE-639)	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	**6.5 (Medium)**	CV-8
T-04	Process 2.0 Transfer	Tampering / Spoofing (CWE-352)	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N	**6.5 (Medium)**	CV-10
T-05	Process 2.0 Admin Console	Tampering (CWE-1021 Clickjacking)	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N	**4.3 (Medium)**	CV-16

3. Attack Tree Summary

• **Attack Tree 1 (Command Injection):** Goal = Host RCE. Attacker accesses `/diagnostics`, submits `127.0.0.1; whoami`. Mitigated by eliminating shell interpretation via `subprocess.run(shell=False)` with a regex whitelist.
• **Attack Tree 2 (Buffer Overflow):** Goal = Hijack execution. Attacker uploads an oversized header payload. Unchecked `strcpy()` smashes stack. Mitigated by bounded `memcpy`/`snprintf` and `-fstack-protector-strong`.

4. Residual Risk Statement

With all mitigations implemented, all Critical and High risks have been successfully reduced to Negligible or Low. The residual risk profile satisfies production enterprise deployment standards.